MÓDULO 6

A08 — Fallos de Integridad de Software o Datos

OWASP Top 10:2025 | Java 17 · Jakarta EE 11 · PostgreSQL 16

50 diapositivas · Componentes · Actualizaciones · Datos · CI/CD



Ruta de aprendizaje

A08:2025 y alcance › Integridad de componentes › Integridad de datos y procesos › Prevención, pruebas y cierre

A08:2025 en OWASP Top 10

- A08:2025 conserva el puesto #8 y aclara el alcance con el nombre “Fallos de Integridad de Software o Datos”.
- El cambio de “y” a “o” destaca que la falla puede afectar al software, a los datos o a ambos.
- El foco está en verificar la integridad de código, artefactos, actualizaciones y datos críticos dentro de límites de confianza.

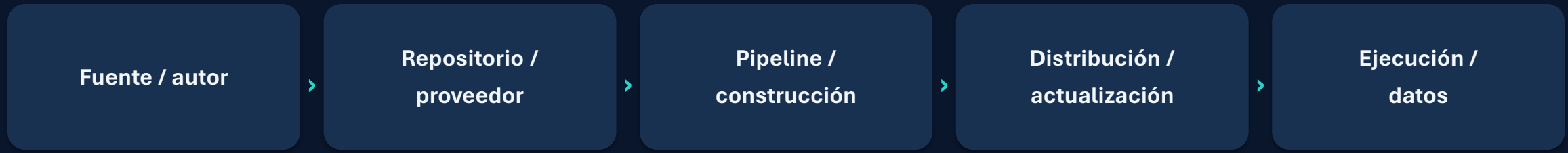
IDEA CLAVE · No basta con que un componente funcione: debe ser auténtico y no haber sido alterado.

Qué significa integridad en A08

- La integridad busca que el software, el código, los artefactos y los datos no sean modificados de forma no autorizada o inadvertida.
- La autenticidad ayuda a determinar quién o qué produjo un elemento y si procede de una fuente esperada.
- La verificación de integridad permite detectar alteraciones; una firma digital puede aportar autenticidad y evidencia de manipulación.

IDEA CLAVE · Integridad no es sinónimo de disponibilidad ni de confidencialidad.

A08 y sus límites de confianza



Componentes: dónde puede romperse la confianza

- Bibliotecas, plugins y módulos externos incorporan funcionalidad que puede ejecutarse con privilegios de la aplicación.
- Un paquete puede provenir de un repositorio inesperado, de una cuenta comprometida o de una ruta de búsqueda manipulada.
- La confianza en el nombre del paquete o en su ubicación no demuestra que el contenido sea legítimo.

IDEA CLAVE · La procedencia debe ser verificable; el nombre del paquete no es una prueba.

Repositorio confiable: política mínima

Orígenes permitidos

Definir repositorios aprobados y bloquear descargas ad hoc desde sitios arbitrarios.

Versiones controladas

Fijar versiones y revisar cambios; evitar rangos abiertos en componentes críticos.

Repositorio interno

Para perfiles de riesgo elevado, considerar un repositorio interno de versiones verificadas.

Trazabilidad

Registrar coordenadas, versión, hash, origen, fecha y responsable de aprobación.

Verificación de integridad: hash vs firma

Hash criptográfico

Compara bytes con un valor esperado obtenido por un canal confiable. Por sí solo no prueba quién generó el archivo.

Firma digital

Vincula el contenido con una clave privada; se verifica con una clave pública confiable.

Canal de confianza

La clave pública, el manifiesto o el hash esperado deben obtenerse de una fuente protegida.

Flujo de verificación de un artefacto



CWE-494: descarga sin verificación

- CWE-494 describe la descarga de código sin comprobar su integridad antes de ejecutarlo o instalarlo.
- El riesgo aumenta cuando la descarga ocurre automáticamente, con privilegios elevados o en múltiples instalaciones.
- La mitigación combina fuente confiable, firma o mecanismo equivalente, validación de versión y rechazo ante discrepancias.

IDEA CLAVE · Nunca ejecutar una actualización solo porque la descarga terminó correctamente.

Diseño seguro del actualizador

- Validar versión, producto, canal, arquitectura, caducidad y política de downgrade.
- Instalar de forma atómica o con mecanismo de rollback seguro; no dejar el sistema en estado parcial.
- Proteger claves de firma y separar la capacidad de publicar de la capacidad de aprobar.

IDEA CLAVE · La actualización debe fallar de forma segura si no puede verificarse.

Caso hipotético: paquete sustituido

- Un equipo necesita una biblioteca para procesar estados de cuenta y no encuentra la versión esperada en el repositorio habitual.
- Descarga un archivo desde un sitio alternativo y lo incorpora manualmente al build.
- El archivo contiene código adicional que exfiltra datos de prueba o altera resultados en el entorno de validación.
- El ejercicio consiste en identificar qué controles habrían detenido la incorporación.

IDEA CLAVE · La urgencia operativa no debe convertir una fuente desconocida en una fuente confiable.

CWE-915: modificación dinámica de atributos

- CWE-915 aborda la modificación controlada de forma inadecuada de atributos de objetos determinados dinámicamente.
- Un patrón frecuente es enlazar directamente un objeto de entrada con una entidad persistente (mass assignment).
- Un cliente podría intentar incluir campos que no deberían estar bajo su control: rol, estado, propietario o marca de aprobación.

IDEA CLAVE · Usar DTOs explícitos y asignar en servidor únicamente los campos permitidos.